GAU-SEVAK

V2.1

CORRECTED MASTER PROMPT

Authoritative correction and replacement pack for the original 105-page V2.0 specification

Review baseline: 09 November 2026

India-first charitable donation marketplace | Flutter + React + Firebase + Razorpay Route

READ THIS FIRST

This document is a corrective override pack, not a claim that the original PDF has been fully rewritten or that the platform is legally approved. Where this pack conflicts with the original V2.0 PDF, this V2.1 pack controls. Items requiring a practising lawyer, CA, bank or Razorpay approval are explicitly marked as gates.

Prepared from a review of the supplied 105-page “Final Prompt.pdf” and official/current reference material available on 09 November 2026.

1. Executive decision

The original V2.0 document contains a strong product vision and broad feature coverage, but it mixes architecture proposals, legal conclusions, unverified provider API assumptions and self-awarded production-readiness scores. The corrections below address the highest-risk defects before implementation.

CURRENT RELEASE STATUS: BLOCKED FOR REAL-MONEY PRODUCTION

Use this patch to guide architecture and sandbox development. Do not accept live donations, issue tax certificates or enable foreign contributions until the relevant legal, tax, bank and payment-provider gates in Section 14 are signed off and the corresponding integration tests pass.

Area	V2.0 issue	V2.1 decision
Payments regulation	₹25 Cr annual donation volume described as PA licence trigger.	Remove turnover trigger. Obtain a written classification of the exact donation flow under RBI PA Directions 2025 and a written Razorpay acceptance of the charity marketplace model.
Tax certificates	Uses old Income-tax Act 1961 / Forms 10BD and 10BE for all years.	Use Income-tax Act 2025 and Forms FN 113 / FN 114 for tax years governed by the new Act; retain legacy mapping only for prior tax periods.
PAN rule	PAN mandatory merely because an individual donation is ₹2,000 or more.	Delete this threshold. The ₹2,000 rule concerns cash-mode deduction eligibility, not a universal PAN threshold. Collect only what current forms and approved policy require.
FCRA / NRI	Blocks all NRIs / international cards and assumes a second arbitrary FCRA bank account.	Classify by citizenship/source and legal route. Indian-citizen NRI personal savings via normal banking channels are not FC under MHA FAQ; FCRA receipt account must follow statutory designated-account rules.
DPDP	Claims blanket India-only data localisation is mandatory and deletion always takes 30 days.	Implement the Act/Rules by their phased commencement; no blanket localisation statement. Maintain purpose-based retention, grievance and deletion workflows.
Webhook	Assumes Firestore supports SQL-style UNIQUE / ON CONFLICT and invents a webhook timestamp check.	Verify HMAC over raw request body; deduplicate on provider event ID with a real unique constraint; persist before ACK; process asynchronously.
Ledger	Partitioned PostgreSQL table has global unique/PK constraints that omit partition key; refunds counted ambiguously.	Start unpartitioned; use append-only events with unique source references. Partition only after measured need and valid keys.
Runtime / hosting	Node.js 20 and Firebase Dynamic Links; Typesense HA proposed as stateful Cloud Run nodes.	Use a currently supported runtime (Node.js 22 baseline on review date), replace Dynamic Links, and host stateful search on a persistence-capable platform.
Recurring payments	Daily scheduler appears to create charges despite provider-managed mandates.	Razorpay Subscription performs mandate-based charging; scheduler handles reminders, expiry, reconciliation and exception workflows only.
Readiness score	Claims 9/10 architecture and 10/10 compliance without evidence.	No numerical readiness score. Status must be Not assessed / Designed / Implemented / Tested / Independently approved.

2. How to apply this correction pack

1. Keep the original 105-page PDF as historical context. Do not ask an AI coding tool to treat it as the final authority without this pack.
2. Provide both the original PDF and this V2.1 document to the engineering team or coding assistant.
3. Apply the replacement rules in this pack wherever the original Parts listed in Section 3 conflict with this version.
4. Do not silently implement “TBD” legal, banking, payment-provider or tax assumptions. Convert them into explicit launch gates and track the evidence.
5. Update the canonical source and architecture decision records (ADRs) together. Remove superseded claims from the future consolidated master prompt.

Suggested system instruction for your coding assistant

Treat Gau-Sevak V2.1 Corrected Master Prompt as the controlling specification. The original V2.0 PDF is legacy context only. Never invent legal conclusions, provider API fields, webhook headers, compliance thresholds or “production-ready” status. When a requirement depends on Razorpay, RBI, FCRA, Income-tax, DPDP, GST or another external authority, cite the current official specification and stop for approval if the exact use case is not covered.

3. Change register: original PDF sections to override

Original PDF reference	Required action
Part 2.1, page 2	Replace PA classification, ₹25 Cr threshold statement and PMLA/KYC assertions.
Part 2.2, page 2; Part 27, pages 46–49	Replace 80G / 10BD / 10BE workflow for new tax years with 2025 Act Section 133 and FN 113 / FN 114; keep transition handling.
Part 2.3, pages 2–3; Part 31, pages 54–56	Replace the NRI, international payment and FCRA account logic.
Part 2.4, page 3; Part 32, pages 56–57	Replace blanket data localisation, deletion deadline and blanket PMLA retention statements.
Part 2.7, pages 3–4; Part 5.2, page 16	Replace refund guarantees and “platform escrow” terminology.
Part 3.1–3.2, pages 4–5	Replace Node 20, Firebase Dynamic Links and stateful Typesense-on-Cloud-Run decisions.
Part 4.2–4.5, pages 10–14	Replace partitioned table constraints, webhook idempotency storage and Firestore admin/security assumptions.
Part 5.1, pages 15–16; Part 6, pages 17–18	Replace webhook, payment retry, refund, reconciliation and function-trigger logic.
Part 7.3, page 20	Replace last-three-donations knowledge-based account recovery.
Part 8.2, page 23	Remove generic “donations above ₹10,000” TDS threshold.
Part 10, page 24	Use current FCM Admin SDK method and verify current batch/API semantics before coding.
Part 12 / Part 16 / Part 19 / Part 38	Re-baseline infra, cost, SLO/DR and go-live checklists from actual quotes and tests.
Part 24–25, pages 38–44	Correct KYC status lifecycle, recurring subscription states and scheduler responsibilities.
Part 30, pages 53–54	Add separate CSR implementing-agency eligibility and CSR-1 checks; do not equate 80G status with CSR eligibility.
Part 60, pages 101–104	Delete self-certified readiness scores; replace with evidence-based release gates.

4. Replacement Part 2 - Legal, tax and regulatory foundation

2.1 Payment Aggregator classification and Razorpay structure

Do not assume that the platform is automatically a Payment Aggregator solely because it facilitates charitable donations. The RBI 2025 Master Direction defines PA activity by reference to aggregating customer payments to merchants for purchase of goods, services or investment products and subsequently settling funds to those merchants. Whether a pure donation marketplace and the proposed settlement path fall within the definition, or within a provider-specific marketplace/Route arrangement, requires a written legal classification of the exact facts.

The old sentence “own PA licence required when annual donation volume exceeds ₹25 Cr” is incorrect and must be removed. Under the RBI 2025 PA Directions, the ₹15 crore and ₹25 crore figures are minimum net-worth milestones for an entity seeking PA authorisation: ₹15 crore at application and ₹25 crore by the end of the third financial year after authorisation. They are not annual donation-volume thresholds.

Before production, obtain: (a) a signed opinion from Indian payments counsel on the operator’s role, funds flow and whether any authorisation/registration applies; (b) written Razorpay approval for the exact charitable-donation marketplace use case, linked-account model, refunds, transfer holds, international payments and recurring donations; (c) confirmation of merchant onboarding, settlement, disputes, escrow/settlement and prohibited-business rules; and (d) confirmation of any FIU-IND obligations if the operator is classified as a non-bank PA / reporting entity.

The platform must not receive donor money into its ordinary operating bank account or describe funds as “escrow” unless the actual licensed PA arrangement and contract support that structure. Do not imply that a third-party PA licence automatically covers every marketplace structure. Provider approval must cover the exact model in writing.

2.2 PMLA, KYC and record retention

Delete the universal statement that every donor must undergo full PAN plus ID verification after ₹50,000 per year as a PMLA statutory threshold. If retained as a business risk rule, label it “internal risk-based policy”, document its rationale, proportionality, consent and privacy impact, and obtain legal review. Apply statutory KYC / AML / record-keeping obligations only to the entity and activity that is actually regulated. If the platform is a PA, implement the due-diligence and FIU-IND obligations that apply to that PA role.

Use a written record schedule by record class: payment evidence, tax reporting evidence, KYC evidence, consent records, support communications, analytics and security logs. Store the legal basis, retention start event, retention duration, access controls and disposal method for each class. Do not assign one blanket five-year retention period to every document without a specific legal basis. Never destroy a record subject to a valid legal hold; never call a general business preference a statutory hold.

2.3 Income-tax Act 2025: donation deduction and certificates

For tax years governed by the Income-tax Act, 2025 (effective from 1 April 2026), update the donation-deduction and reporting workflow. The current Act uses Section 133 for the corresponding donation deduction framework, and Section 354(1) for reporting particulars of donations. Under the Income-tax Rules, 2026, Form FN 113 is the donee organisation’s statement of donation particulars and Form FN 114 is the donor’s acknowledgement/certificate generated after the relevant filing and processing. The official FAQ states that FN 113 is to be filed electronically before 31 May immediately following the tax year.

For tax periods governed by the repealed Income-tax Act, 1961, preserve transition handling for the legacy Forms 10BD / 10BE where applicable. Do not generate one legacy or new form across all years without checking the relevant tax period and transition provisions. A CA must validate the migration of each Gaushala’s registration / approval status from the old Act and confirm the exact eligibility data, return process, form fields, amendment/correction process and certificate issuing authority.

Remove “PAN mandatory for donations ≥ ₹2,000”. The ₹2,000 rule is about the mode of donation and deduction eligibility for cash donations above that limit; it is not a universal PAN threshold. Do not promise a deduction to every donor or every donation. Eligibility depends on the donee’s valid approval, the nature and mode of payment, applicable statutory limits and donor tax facts. The platform should say “tax benefit may be available subject to applicable law and donee eligibility”, not “eligible” as a guaranteed outcome. Section 133(6) also makes donor claims for the relevant approved institution/fund dependent on donation information furnished by the donee to the prescribed authority and verification under the Board’s risk-management strategy; build data accuracy, correction and acknowledgement into the donee workflow.

Platform responsibilities: capture only the donor/donation particulars required by the applicable form and the donee’s approved process; give the donee a reviewed export; preserve immutable correction history; record the filed Form FN 113 acknowledgement and FN 114 issuance/availability; and never represent a platform-generated draft PDF as a statutory certificate unless the process legally authorises that generation. The registered donee remains accountable for accurate filing and certification.

2.4 FCRA: correct donor classification and receiving account

Do not classify every NRI donation as foreign contribution. The Ministry of Home Affairs FAQ states that a donation from an Indian citizen living abroad (NRI), from personal savings and through normal banking channels, is not foreign contribution; the FAQ recommends obtaining passport details to establish Indian citizenship. A donation from an Indian-origin person who has acquired foreign citizenship, including an OCI / PIO cardholder, is treated as foreign contribution. Use citizenship/source classification, not residence, card type or card BIN alone.

For a registered/prior-permission recipient, the FCRA receiving route must comply with the designated FCRA account requirements. MHA guidance states that foreign contribution must be received in the designated SBI Main Branch, New Delhi FCRA account; an eligible organisation may also maintain other FCRA account(s) at scheduled banks for transfer/utilisation subject to the Act and rules. A generic second bank account or an arbitrary second Razorpay Linked Account is not a substitute for the statutory designated receipt account.

Before enabling any foreign-source donation, the Gaushala must have valid registration or prior permission covering the contribution, an approved donor/cause path, correct designated-account details, and written bank/provider confirmation that the exact payment and settlement flow is lawful and supported. If any classification is uncertain, block that payment and send it to manual compliance review. Do not describe “international card = foreign contribution” as a complete legal test.

As of the review date, the FCRA Amendment Rules, 2026 have been notified; the FCRA Amendment Bill, 2026 is a separate legislative proposal and must not be treated as enacted law until the official status changes. Maintain a compliance-change register and re-check MHA notifications before enabling foreign donations.

2.5 DPDP Act and Rules - phased commencement

Remove the claim that the DPDP Act requires all personal data to be stored only in Mumbai. The Act provides for government-notified restrictions on transfer to certain countries/territories; it does not create a universal blanket localisation rule for every data fiduciary. Select India-region storage as a security, latency, contractual or risk decision if appropriate, but do not mislabel it as a general legal mandate.

The Digital Personal Data Protection Rules, 2025 were notified with phased commencement. Rules 1, 2 and 17–21 commenced on publication; Rule 4 commences one year after publication; Rules 3, 5–16, 22 and 23 commence eighteen months after publication. Build a dated compliance matrix against the Gazette commencement schedule. As at 9 November 2026, do not mark future-effective provisions as already fully in force; do implement the required controls ahead of their effective dates.

Build: clear notices and purpose limitation; consent/withdrawal where consent is the relied-on basis; a grievance channel; access/correction/erasure workflow; processor/vendor contracts; breach detection and response; security safeguards; retention/deletion rules; and a legal exception register for data that must be retained. An erasure

request must trigger identity verification and a record-by-record legal retention review. It must not blindly delete financial evidence or blindly retain all personal data under a generic “PMLA override”.

2.6 GST, TDS and CSR

GST: do not encode a single ₹20 lakh trigger as a universal registration rule without testing the entity type, state, supply classification, exemptions, aggregate turnover, inter-state position and current notifications. A donation itself, platform service fee, payment processing fee and reimbursement can have different GST treatment. A CA must approve the fee model, invoice issuer, tax point, place of supply, SAC/HSN, input tax credit and reconciliation logic.

TDS: delete the generic rule “donations above ₹10,000 flagged for TDS”. A donation is not automatically subject to TDS simply because it exceeds ₹10,000. TDS controls must be mapped to the actual nature of a payment (salary, contractor, rent, professional fees, etc.), payer/payee relationship and the applicable provision/threshold for the relevant tax year.

CSR: Section 135 / Schedule VII eligibility is not established merely because an entity is a Section 8 company, trust or holds tax-deduction approval. Add a separate CSR implementing-agency checklist, including applicable CSR-1 registration and the current Companies (CSR Policy) Rules, eligibility class, track record, project category and reporting obligations. Keep CSR donations on a separate data and approval path.

2.7 Refunds, disputes and suspended recipients

Replace the universal “7-day refund for any reason” and automatic “refund last 30 days” commitments with a published refund policy approved by counsel, the receiving charity and the payment provider. The policy must distinguish duplicate/failed payment, donor cancellation request, misdirected payment, fraud, chargeback, regulatory hold and recipient suspension. It must explain who has authority to decide, who bears processing fees, what happens after transfer/settlement, and the expected provider-dependent timeline.

Never promise that settled money can always be pulled back. A fraud/suspension incident should immediately stop new donations, suspend the recipient listing, stop future transfers where the provider allows, preserve records, assess pending and settled funds, notify affected stakeholders, and follow an approved refund/recovery plan. Use the phrase “provider-supported hold / transfer pause” only where enabled and contractually confirmed. Do not call a payment-provider hold an “escrow” unless the legal arrangement actually is an escrow account.

5. Replacement Part 3 - Platform architecture

5.1 Approved baseline stack

Layer	V2.1 baseline	Implementation note
Mobile	Flutter / Dart; Riverpod; GoRouter	Android first if needed; iOS only after its own compliance and security checks.
Admin	React + TypeScript + Ant Design or shadcn/ui	Choose one UI system and record it in an ADR; do not leave “or” in the final spec.
Backend	Firebase Cloud Functions v2 / Cloud Run functions; TypeScript; Node.js 22 baseline on review date	Node.js 20 reached decommission on 30 Oct 2026; verify runtime support before each deploy.
Primary app store	Firestore in asia-south1 if selected	Application read model / operational data. Financial truth must be reconciled against the ledger.
Financial ledger	Cloud SQL for PostgreSQL	Choose one authoritative ledger design. Use database transactions and unique provider references.
Queue / events	Pub/Sub or Cloud Tasks	Use a transactional outbox or equivalent to avoid lost publish between DB commit and queue publish.

Layer	V2.1 baseline	Implementation note
Search	Typesense Cloud or a persistent-volume-capable GKE/GCE deployment	Do not run a stateful multi-node Typesense cluster on ordinary stateless Cloud Run containers.
Deep links	Android App Links + iOS Universal Links + first-party web fallback	Firebase Dynamic Links is shut down; do not use it.
Files	Cloud Storage / Firebase Storage	Private files need short-lived signed URLs, strict IAM, malware/type checks and retention controls.
PDF	Cloud Run stateless PDF worker	Idempotent job, authenticated service-to-service calls, queue retry and dead-letter queue.
Secrets	Google Secret Manager + least-privilege service accounts	Separate dev/staging/prod projects and secret versions.

5.2 Cloud Run and stateful service rule

Cloud Run instances are designed for stateless services. Use Cloud Run for API workers, PDF rendering, webhook processing and other stateless jobs. Do not rely on a container's local filesystem for persistent database state. For Typesense HA, use a managed Typesense service or a platform with persistent disks, stable node identities, network discovery, backups and recovery testing. Document shard/replica topology, backup restore procedure, version upgrade policy and failure runbook.

5.3 Deep-link replacement

Firebase Dynamic Links must be removed from the architecture. Use first-party HTTPS links on a domain controlled by Gau-Sevak. Configure Android App Links (assetlinks.json) and iOS Universal Links (apple-app-site-association). Every shared URL must have a web fallback so users without the app can view a public Gaushala/campaign page. Receipt URLs remain authenticated and must not expose predictable donation identifiers or private details.

6. Replacement Part 4 - Data, ledger and security

6.1 One financial source of truth

Define Cloud SQL as the authoritative financial ledger and Firestore as an application read model/projection. A payment is not financially complete merely because a Firestore document changed. The backend must reconcile provider payment, transfer and settlement records against the immutable ledger. Store money as integer paise and currency explicitly. Do not use floating point for accounting.

Use separate entities for the donor intent, payment attempt, provider payment, transfer, settlement, refund, reversal and certificate. A retry must create a new payment attempt; never overwrite the prior order/payment identifier in the original donation record. Aggregate counters such as totalDonors must use a unique donor-to-Gaushala relationship or a deduplicated event key; never increment a distinct-donor counter just because a webhook was received.

Entity	Purpose / key rule
donation_intents	User's intended donation to a Gaushala; stable business intent ID.
payment_attempts	One row per provider order/checkout attempt; attempt sequence, provider order ID, amount, state, failure reason.
provider_payments	Provider payment ID, captured amount, currency, method and provider status; unique provider payment ID.
transfers	One or more transfers to beneficiary Linked Account; provider transfer ID and state tracked independently.

Entity	Purpose / key rule
settlements	Provider settlement references and settlement dates; do not conflate transfer with bank credit.
refunds / reversals	Refund ID, original payment/transfer references, amount, reason, state and provider confirmation.
ledger_events	Append-only financial event record; every reversal is a new linked event, never mutation/deletion of the original event.

6.2 PostgreSQL partitioning correction

The original partitioned table uses a primary key and UNIQUE payment ID without including the partition key. PostgreSQL requires a partitioned table's PRIMARY KEY/UNIQUE constraint to include all partition-key columns. The original DDL therefore cannot enforce the intended global uniqueness as written. The original single example partition for January 2025 is also not a complete rolling-partition strategy. The generated financial year must be derived from the CA-approved recognition/posting date in the India tax-year calendar, not blindly from an order-created timestamp.

V2.1 decision: start with an unpartitioned financial ledger. Add indexes based on measured query patterns. Introduce time partitioning only after production-like volume tests, a migration plan and a retention/archive design. If partitioning is introduced, either include the partition key in every required unique/primary-key constraint or maintain global uniqueness in a separate unpartitioned reference table.

```
-- Safe starting point: unpartitioned append-only ledger events
CREATE TABLE ledger_events (
  ledger_event_id UUID PRIMARY KEY,
  source_system TEXT NOT NULL,
  source_event_id TEXT NOT NULL,
  donation_id TEXT NOT NULL,
  event_kind TEXT NOT NULL,
  amount_paise BIGINT NOT NULL CHECK (amount_paise >= 0),
  currency CHAR(3) NOT NULL CHECK (currency = 'INR'),
  occurred_at TIMESTAMPTZ,
  recorded_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  reverses_ledger_event_id UUID REFERENCES ledger_events(ledger_event_id),
  UNIQUE (source_system, source_event_id)
);
-- Enforce append-only for the application role; corrections are new linked events.
```

Accounting note: an event table is not automatically a balanced double-entry ledger. Before real-money launch, a CA/accounting architect must define accounts, debit/credit postings, fee/GST treatment, settlement clearing, transfer liability, refunds and reconciliation rules. Enforce balanced journal batches in one SQL transaction.

6.3 Webhook idempotency storage

Do not use SQL syntax such as ON CONFLICT against a Firestore collection. Firestore does not provide arbitrary unique-field constraints. Pick one durable event inbox. Recommended: a PostgreSQL table with a unique key on (provider, provider_event_id), plus status, receive time, processing attempts, last error and processed time. If Firestore is used instead, use the provider event ID as the document ID and create the document atomically; do not claim SQL uniqueness semantics.

```
CREATE TABLE provider_webhook_events (
  provider TEXT NOT NULL,
  provider_account_id TEXT NOT NULL,
  environment TEXT NOT NULL CHECK (environment IN ('test', 'live')),
  provider_event_id TEXT NOT NULL,
  event_type TEXT NOT NULL,
  received_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  processed_at TIMESTAMPTZ,
  processing_state TEXT NOT NULL DEFAULT 'received',
  retry_count INTEGER NOT NULL DEFAULT 0,
  last_error TEXT,
  PRIMARY KEY (provider, provider_account_id, environment, provider_event_id)
);
```

Persist only the minimum payload needed for processing and audit. If storing raw payload is required, encrypt it, restrict access, redact unnecessary personal/payment data and define a retention policy. Never store card PAN, CVV, OTP or sensitive authentication data.

6.4 Firestore security rules - required rewrite

The original membership lookup assumes a document ID of uid_gaushalid but the schema calls the key recordId. It also treats owner/editor/viewer as interchangeable. Use a deterministic membership ID or a consistent membership lookup design. Every operation must check the relevant role. Cloud Functions/Admin SDK access bypasses Firestore Security Rules; protect server code with IAM, authenticated service identity, explicit tenant authorization and validation. Donor-created refund requests must be checked server-side against the authenticated donor's captured donation, refundable balance and existing requests; never trust a client-supplied donationId, requestedBy, reasonCategory or status. Apply equivalent least-privilege rules to Cloud Storage and Cloud SQL.

Replace blacklists on self-service profile updates with allowlists. A user must never be able to create or edit server-controlled fields such as account status, PAN, KYC state, balances, donation counts, admin roles or verification badges.

```
rules_version = '2';
service cloud.firestore {
  match /databases/{database}/documents {
    function signedIn() { return request.auth != null; }
    function isSelf(uid) { return signedIn() && request.auth.uid == uid; }

    match /users/{uid} {
      allow read: if isSelf(uid);
      allow create: if isSelf(uid)
        && request.resource.data.keys().hasOnly([
          'name', 'email', 'locale', 'createdAt'
        ]);
      allow update: if isSelf(uid)
        && request.resource.data.diff(resource.data).affectedKeys()
          .hasOnly(['name', 'email', 'locale', 'notificationPreferences']);
      allow delete: if false; // deletion through controlled server workflow
    }

    match /donations/{donationId} {
      allow read: if signedIn() && resource.data.userId == request.auth.uid;
      allow create, update, delete: if false;
    }

    // Admin membership, financial records and KYC data are server-managed.
    // Admin API must verify tenant + role + object-level permissions.
  }
}
```

This snippet is a pattern, not a complete deployable ruleset. Add tests for missing auth, mass assignment, cross-tenant reads, owner/editor/viewer permissions, query constraints and malicious field injection before deployment.

6.5 Lifecycle enum consistency

The original prompt uses status values in workflows that do not exist in the declared schema. Reconcile every enum before code generation. At minimum: accountStatus must include deletion_requested if that state is persisted; Gaushala application workflow (draft, submitted, under_review, kyc_pending, kyc_approved, active, rejected, kyc_rejected, suspended, deactivated) must match the schema or be separated into applicationStatus and operationalStatus; subscription states must include the provider lifecycle states or store providerStatus separately; refund and transfer lifecycles must not be collapsed into one payout status. Tax certificate records must store the applicable tax law/form/version and donee filing acknowledgement rather than a boolean that is always true.

7. Replacement Part 5 - Payment, webhook, refund and settlement lifecycle

7.1 One-time donation flow

1. Flutter submits a donation intent to an authenticated HTTPS function. The backend takes userId from the verified Firebase token, never from a client-supplied field.
2. Backend validates Gaushala status, approved linked account, KYC validity, allowed amount/currency, limits, fee policy and FCRA decision. Reject if any beneficiary or account gate is not satisfied.
3. Backend first persists a payment_attempt using a stable client request-id/idempotency key scoped to the authenticated user and donation intent. Repeating the same createOrder request returns the existing attempt/order rather than creating another one. Backend then creates the Razorpay Order and stores the provider order ID. Use the exact currently supported Route order/transfer API and payload confirmed in the active Razorpay account/docs. Do not invent fields.
4. Flutter opens Razorpay Checkout with the backend-created order ID. Client success callback is only a UX signal; it is not the source of truth for capture.
5. Razorpay webhook receiver verifies the signature over the exact raw request body using the configured webhook secret.
6. Receiver stores the unique provider event durably. Return a 2xx response only after durable acceptance. Duplicate event IDs are acknowledged without repeating business effects.
7. A background worker processes the event transactionally: validate provider account, event type, order/payment IDs, amount and currency; post ledger event; update payment projection; enqueue outbox event.
8. A separate worker sends receipt notifications and, when eligible, tax-reporting data to the donee workflow. PDF generation must not block the webhook.
9. Transfer and settlement states are updated from their own provider events/reconciliation feeds. “Captured” is not the same as “transferred” or “settled”.

7.2 Webhook receiver - replacement logic

```
// Pseudocode: adapt to the actual Razorpay SDK and raw-body support.
const rawBody = request.rawBody;
const signature = request.header('X-Razorpay-Signature');
if (!verifyHmacSha256(rawBody, signature, webhookSecret)) {
  return response.status(400).send('Invalid signature');
}

const eventId = request.header('x-razorpay-event-id');
if (!eventId) return response.status(400).send('Missing event ID');

// Insert provider + eventId into a SQL table with a UNIQUE/PRIMARY KEY.
// If it already exists, acknowledge the duplicate and do not re-run effects.
// Commit the durable inbox row before returning 2xx.
// Background worker processes inbox -> ledger -> transactional outbox.
return response.status(200).send('accepted');
```

Do not require a made-up webhook timestamp field. Use only documented headers and signature verification. If the provider does not give a signed timestamp for the configured webhook scheme, do not claim timestamp validation prevents replay. Replay/deduplication is handled by event-ID uniqueness, idempotent processing, provider event age policy where documented and reconciliation.

7.3 Payment retries and state model

Never overwrite the first order ID when a donor retries. Keep the donor intent stable and append a new payment attempt per checkout. Suggested states: intent (draft, submitted, expired, completed, cancelled); payment attempt (created, authorized, captured, failed, expired, refunded, disputed, partially_refunded); transfer (created, pending, processed, failed, reversed, on_hold); settlement (pending, settled, delayed, failed). Keep provider status and normalised internal status separately.

7.4 Refund and transfer reversal

Refund processing must verify current payment state, remaining refundable amount, provider refund limits, linked transfer status, dispute status and duplicate requests. Use the documented provider refund and transfer-reversal flow for the account. Do not automatically issue two separate operations if the provider refund path itself reverses a linked transfer. Store every provider refund/reversal ID and wait for the authoritative event/status before marking complete. Post an append-only reversal journal entry; never delete or rewrite the original capture event.

If funds have already settled to the Gaushala, recovery may require a provider-supported negative balance, future settlement adjustment, recipient repayment or legal process. Do not promise a platform-initiated clawback unless the provider contract and account configuration support it.

7.5 Suspension and “escrow” wording

On suspension: stop new donation intents; remove recipient from search; stop new subscription renewals where provider permits; prevent new transfers; place eligible pending transfers on provider-supported hold only where enabled; preserve money and audit state; notify donors. Releasing or refunding funds requires a documented decision and provider confirmation. Never call withheld settlement “platform escrow” unless a legally constituted escrow account exists and the licensed arrangement identifies it as such.

8. Replacement Part 25 - Recurring donations

Razorpay Subscriptions manages the mandate and scheduled debit under the configured plan. Do not run an application scheduler that independently charges the customer on every due date; that risks duplicate collection. The daily scheduler is for reminders, missed-webhook monitoring, stale mandate detection, reconciliation and exception queues. A provider subscription charge webhook creates one unique payment record and one corresponding donation ledger event.

Confirm in writing that the merchant account is enabled for the exact combination of Razorpay Subscriptions and Route linked-account transfer. Treat “charge captured then Route transfer” as a design hypothesis until Razorpay confirms the supported API sequence, settlement timing, reversal behaviour and webhook set for this merchant account. Disable recurring donations until sandbox and production-readiness evidence exists.

Do not describe total_count=120 as indefinite; it is a finite ten-year count for monthly billing. Show the end/renewal terms clearly and provide a donor-managed cancellation path. Do not automatically resume a paused mandate after 90 days without explicit donor action/consent. On amount change, follow the provider’s current plan/subscription rules and require any re-authorisation the provider mandates.

Provider event / state	Internal action
subscription.activated	Mark mandate active only after verified webhook; store mandate ID, plan, amount and next charge date.

Provider event / state	Internal action
subscription.charged	Idempotently create payment attempt/payment/donation ledger entry; then follow the approved transfer flow.
subscription.pending	Show pending collection and send appropriate reminder; do not mark payment captured.
subscription.halted	Stop treating it as active; create support/recovery action and notify donor. Do not silently create a fresh mandate.
subscription.paused / resumed	Reflect provider state; resume only after a valid donor/provider-authorised action.
subscription.cancelled / completed	Stop future collection and preserve mandate history.

9. Replacement Parts 7, 8 and 10 - Identity, admin and notifications

9.1 Account recovery

Remove “last three donations knowledge authentication”. Donation amounts, dates and recipient names are not secrets and may be known, guessed or exposed. Use verified access to the existing phone/email, step-up verification, recovery delay, risk checks, support-assisted identity review and an audit trail. Do not reveal whether an account exists. Revoke existing sessions/tokens after a high-risk recovery event.

9.2 Admin roles and donor information

Enforce role-based, tenant-scoped permissions on the server, not just by hiding buttons in React. Define permission matrix for owner, editor and viewer. Export of donor identity requires a separate consent purpose, explicit scope, access expiry, audit trail, export watermark and rate limit. For tax filing, share only fields legally required by the donee reporting process, not a blanket donor-contact export.

9.3 Push messaging

Use the current Firebase Admin SDK method supported by the exact pinned SDK version. The older `sendMulticast` wording should not be copied without checking the SDK migration status; use the currently supported multicast/send-each API and chunk within the provider limit. Treat FCM as best effort. Payment success must be visible from server-side history even when push/SMS delivery fails. Register DLT headers/templates and obtain consent/opt-out treatment for non-transactional messages.

10. Replacement Parts 26, 27, 33 and 34 - search, PDF and resilience

10.1 Search index

Firestore remains the source for public Gaushala profile data; Typesense is a derived search index. The sync worker must handle create/update/delete/suspension, retries, out-of-order events and periodic full reconciliation. Do not expose an admin Typesense key. Search results must re-check current status at the read/API boundary before showing donation actions.

Run Typesense on a managed or persistent infrastructure platform, not as three ordinary Cloud Run containers without durable storage. Include snapshot/restore tests, replica health alerts, schema migration plan and a documented fallback to Firestore queries when search is unavailable.

10.2 Tax PDF service

Rename `Form 10BE` template logic to tax-year-specific certificate generation. For tax years governed by the 2025 Act, use the applicable FN 114 workflow and data structure; for legacy tax periods, use 10BE only where transition rules require. A CA must approve a rendered sample against the official form and filing flow. Store the actual form version, tax year, donee approval validity, source donation IDs, donee filing acknowledgement, generated timestamp and correction/reissue history.

The public verification endpoint must disclose the minimum information needed to verify authenticity. Use unguessable certificate reference IDs, rate limits and anti-enumeration controls. Signed storage links must be short-lived; a seven-year signed URL is not a retention policy. Keep storage object retention separate from URL lifetime.

10.3 Rate limiting

Do not increment a donor's daily donation total before payment capture and then forget to roll it back after failed/cancelled payments. Maintain a short-lived reservation for order creation and a separate captured-total counter. Use an atomic Redis script or transaction for limit checks and reservations, with idempotent decrement/expiry. Set the expiry to the next midnight in Asia/Kolkata for an IST calendar-day bucket rather than assuming a fixed 24 hours from the first request. Reconciliation must clear orphan reservations. A "near limit" policy must never accept above hard limits accidentally.

10.4 Circuit breaker

The original circuit-breaker pseudocode has a race: multiple concurrent callers can all observe half-open and send test calls, and stale local state can incorrectly close the breaker. Use an atomic Redis/Lua lease for a single half-open probe, explicit state transitions, bounded timeout, jittered retries and metrics. Never retry a non-idempotent create-order / refund / transfer call without a stable idempotency key or provider-supported duplicate protection.

11. Replacement Parts 12, 16, 19, 38 and 59 - operations

11.1 Runtime and lifecycle

Use a runtime that is supported on the deployment date. On 9 November 2026, Node.js 20 has passed Google's stated decommission date of 30 October 2026. Use Node.js 22 as the conservative baseline for the current plan and schedule an upgrade review before its next lifecycle milestone. Pin runtime, dependency and SDK versions; scan and patch them continuously.

11.2 Backups and disaster recovery

Use Cloud SQL native automated backups and point-in-time recovery as the primary managed-database recovery path. Do not design a managed Cloud SQL deployment around direct pgBackRest WAL archiving unless the exact managed-service configuration explicitly supports it. Also create encrypted logical exports for portability, store backups in a separate project/account boundary where feasible, test restoration quarterly and record the observed RPO/RTO. "Backup enabled" is not evidence of recoverability.

11.3 SLO and incident response

Define measurable SLOs from actual product risk: successful donation intent creation, provider checkout availability, webhook processing lag, payment-to-ledger reconciliation lag, certificate availability, admin access and search freshness. Alert on the financial invariants: captured provider payments without ledger entries; ledger capture without a provider payment; transfer initiated but failed/stuck; settlement mismatch; duplicate ledger event; certificate generated without valid eligibility; and a suspended Gaushala accepting new donations.

11.4 Cost model

Treat all original monthly cost numbers as preliminary estimates, not a budget or vendor quote. Recalculate by region, instance sizing, database storage/IO, Cloud Functions/Run request volume, log retention, video minutes stored/delivered, SMS segments, email, CDN, backups, support, security audits, tax and payment fees. Model at least low/base/high scenarios with assumptions and a date. Separate variable payment fees from infrastructure costs and staffing/compliance costs.

12. Legal and finance controls still missing or needing design

- Platform operator identity and model: decide whether the operating entity is a for-profit company, Section 8 company or another structure; state who is the donee, who contracts with donors and who receives/controls funds.
- Gaushala eligibility: define which legal entity types can receive money; distinguish informal shelter listing from eligible donee; no donation/tax-benefit promise until bank and tax approvals are verified.
- Agency and beneficiary agreements: written terms covering collection authorisation, platform fees, donor restrictions, use of funds, reporting, refunds, disputes, suspension, audit rights and records retention.
- Donor consent model: separate essential receipt/tax communications from optional marketing and sharing identity with a Gaushala; retain versioned notice and consent evidence.
- Grievance redressal: named grievance officer/contact, acknowledgement SLA, resolution SLA, escalation path, complaint categories, records and regulatory reporting if applicable.
- Chargeback evidence: donor receipt alone may not prove charitable fulfilment. Define what evidence exists (payment authorisation, charity acknowledgement, fund transfer, donation purpose disclosure, communications) and who submits it.
- AML/sanctions screening: only to the extent legally required or justified by provider contract/risk model; define false-positive handling, escalation and data retention.
- GST and accounts: approved chart of accounts for donation liability, platform commission, gateway fees, GST, TDS (where applicable), refund liability, settlement clearing and transfer liabilities.
- CSR route: separate eligibility, CSR-1, Schedule VII, project-level reporting and certificate/tax treatment controls.
- Insurance and liability: cyber, professional indemnity, crime/fidelity cover and charity/beneficiary indemnities should be reviewed with counsel and insurer.

13. Evidence-based production readiness matrix

A document cannot mark a control “implemented” merely because it contains a requirement or sample code. Use this evidence status in the admin tracker and release review:

Status	Meaning	Evidence required
Not assessed	No design review or proof yet.	Owner and due date assigned.
Designed	Architecture/specification reviewed.	Approved ADR, threat model or control description.
Implemented	Code/configuration exists in target environment.	Commit, deployment ID, config evidence and reviewer.
Tested	Automated/manual tests passed.	Test run, expected/actual results, failure handling and logs.
Independently approved	External specialist or authorised party signed off.	Lawyer/CA/provider/security assessor/bank written confirmation.
Production monitored	Live operational performance observed.	SLO dashboard, alerts, on-call owner and incident drill.

Do not assign 9/10 or 10/10 scores to a section until the score methodology is published and every item has evidence. Compliance is not a numerical design score; it is a requirement-by-requirement legal determination plus implemented controls and continuing review.

14. Mandatory launch gates - no real money before all relevant gates pass

Gate	Required evidence	Owner
G1 - Legal funds-flow opinion	Written Indian legal opinion on platform role, PA applicability, money custody, linked-account and refund model.	Founder + payments counsel
G2 - Razorpay approval	Written approval for exact charity donation marketplace, Route linked account, fees, payout holds, refunds/reversals, recurring and any foreign payment flow.	Payments lead
G3 - Donee / bank KYC	Each Gaushala's legal identity, bank account, entity PAN, current registrations, authorised signatory, beneficial/controlling-person checks as applicable; independent bank/provider verification.	Compliance ops
G4 - Tax forms	CA-approved migration of legacy approvals, Section 133 eligibility, FN 113 data mapping, FN 114 sample and correction/reissue process.	CA + donee
G5 - FCRA	No foreign donations until citizenship/source decision tree, valid registration/prior permission, designated SBI account and provider/bank route are approved.	FCRA counsel + bank
G6 - DPDP	Dated commencement matrix, privacy notice, consent records, grievance process, processor contracts, rights workflow, breach response and retention schedule.	Privacy counsel / DPO function
G7 - Ledger / reconciliation	Capture, transfer, settlement, refund, reversal and fees reconcile to provider test reports; no duplicate or missing financial events.	Finance + backend
G8 - Security	Threat model, rules/IAM tests, secret scan, dependency scan, external penetration test and all critical/high findings closed or accepted.	Security lead
G9 - Reliability	Backups restored successfully, incident runbooks, alert drills, load test, queue retry/dead-letter test, provider outage and webhook replay test.	SRE / DevOps
G10 - Customer operations	Published terms, refund/dispute policy, grievance contact, support SLA, suspension communication and incident notification templates.	Product + operations

15. Required test scenarios before accepting real donations

- Duplicate the same webhook event 2, 5 and 20 times; the donor is charged once and exactly one ledger effect is posted.
- Deliver a webhook before the client callback, after the client callback, out of order, with a delayed retry and after a worker crash.
- Razorpay says captured but the Firestore projection update fails; replay/reconciliation repairs it without duplicate ledger events.
- Capture succeeds but the linked-account transfer fails, remains pending, is held or is later reversed.
- Full refund and partial refund; repeat refund request; refund after transfer; chargeback before and after settlement.
- Donor presses Pay twice or retries after network loss; each checkout attempt stays separately auditable.

- Gaushala is suspended while a donation is being paid, while a transfer is pending, and while a subscription is due.
- Gaushala 80G/tax approval expires before donation, after donation but before certificate filing, and after annual reporting.
- Indian-citizen NRI personal-savings donation, foreign citizen / OCI / PIO donation, foreign-card issued to Indian citizen and uncertain donor source; test the approved FCRA decision tree.
- User tries to self-set PAN, accountStatus, totalDonated, KYC status, admin role or donation status; all attempts fail.
- Gaushala admin A attempts to read or export Gaushala B donor/payment records; every cross-tenant path fails.
- Data deletion request with active subscription, open dispute, tax reporting record and valid legal hold; only lawful data is retained.
- Cloud SQL backup restore, point-in-time restore, Typesense index rebuild and Pub/Sub/Cloud Tasks dead-letter recovery.
- Rate-limit concurrency test: simultaneous requests cannot exceed cap through race conditions or leave permanent phantom reservations.

16. Questions that must be resolved by specialists

Question	Required approver
Does the exact donor-to-charity funds flow constitute PA activity or another regulated payment activity under the RBI 2025 Directions? Is any authorisation or PA-provider-only route required?	Indian payments counsel; Razorpay compliance
Does Razorpay Route permit the exact charitable beneficiary setup, sub-merchant structure, platform fee, transfer hold, refund/reversal and recurring transfer sequence for this account?	Razorpay account manager + compliance, in writing
Which donee approvals under Income-tax Act 2025 make each Gaushala eligible, and how must previous 1961 Act approvals transition?	Charity tax CA / tax counsel
Who legally files FN 113 and issues FN 114, and what authority permits the platform to prepare/submit data on the donee's behalf?	Donee + CA + tax counsel
Which donor cases are FCRA contributions and how does the payment aggregator route funds into the designated SBI FC account?	FCRA counsel + bank + Razorpay
Which DPDP provisions/Rules have commenced on launch date and what role is Gau-Sevak: Data Fiduciary, processor, or both for particular purposes?	Privacy counsel
What is the approved GST treatment of platform commission, gateway fee pass-through and refunds? Which TDS sections apply to non-donation vendor payments?	GST / direct-tax CA
Is the charity eligible for CSR implementing-agency status and has CSR-1 / other current registration been verified?	CSR counsel / CA

17. Final authoritative prompt block

COPY THIS BLOCK INTO THE MAIN CODING-ASSISTANT SYSTEM CONTEXT

You are implementing Gau-Sevak using the original V2.0 specification only as legacy context and this V2.1 correction pack as the controlling authority. The platform handles real charitable donations and sensitive identity/tax data. Correctness, lawful funds flow, financial reconciliation, tenant isolation, donor privacy and operational recoverability take priority over feature speed. Never invent legal thresholds, provider API fields, webhook headers, tax form layouts, payment settlement guarantees or security controls. Use official documentation for the exact deployed provider/runtime version. For every money movement, maintain separate payment, transfer, settlement, refund and reversal states with idempotent ledger entries. The payment provider webhook is the authoritative payment event source; client callbacks are not authoritative. Never accept real money until all Section 14 launch gates have documented evidence. For unresolved legal/provider questions, stop that feature and report the exact decision and required approver instead of guessing.

18. Source register and verification notes

The links below are primary or official materials used for the corrections. They were checked for this review on 09 November 2026. Laws, rules, provider documentation, runtime schedules and SDK interfaces can change; verify again at the date of launch and record the version/date in the ADR.

- **RBI - Master Direction on Regulation of Payment Aggregators, 15 Sep 2025 -** PA definition, authorisation, capital/net-worth requirements, merchant due diligence and escrow/settlement requirements. https://www.rbi.org.in/Scripts/NotificationUser.aspx/upload/notification/docs/Scripts/NotificationUser.aspx?Id=12896
- **MHA FCRA FAQ -** NRI Indian-citizen personal savings exception; foreign-citizen/OCI/PIO classification; SBI Main Branch designated account and other FCRA accounts. https://fcraonline.gov.in/home/PDF_Doc/fc_faq_04102022.pdf
- **Income-tax Department - Form 113 & 114 FAQs -** FN 113 / FN 114, Section 354(1), due date and e-filing process. https://www.incometaxindia.gov.in/documents/d/guest/form-113-114-faqs
- **Income-tax Department - Form 113 guidance note -** Form FN 113 purpose, eligible donee reporting and data requirements. https://www.incometaxindia.gov.in/documents/d/guest/fn-113
- **Income-tax Department - Form 114 guidance note -** Form FN 114 donor certificate generated after processing Form FN 113. https://www.incometaxindia.gov.in/documents/d/guest/fn-114
- **Income-tax Department - Income-tax Act 2025 and Rules 2026 -** Official Act, Rules, correspondence tables and transition FAQs. https://www.incometaxindia.gov.in/en/income-tax-act-202511
- **MeitY - Digital Personal Data Protection Rules 2025, Gazette -** Phased commencement of Rules 1–2, 17–21; Rule 4; and Rules 3, 5–16, 22–23. https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686cadad39.pdf
- **Firebase - Dynamic Links deprecation FAQ -** Firebase Dynamic Links is deprecated / shut down; use App Links and Universal Links. https://firebase.google.com/support/dynamic-links-faq
- **Google Cloud - Cloud Run functions runtime support -** Node.js 20 decommission schedule and supported Node.js runtime versions. https://docs.cloud.google.com/functions/docs/runtime-support
- **Google Cloud - What is Cloud Run? -** Cloud Run service model; use persistent storage architecture for stateful workloads. https://docs.cloud.google.com/run/docs/overview/what-is-cloud-run
- **Razorpay - Transfer Funds to Linked Accounts -** Route transfer methods and prerequisites, including Linked Account cooling period. https://d6xcmfyh68wv8.cloudfront.net/docs/payments/route/transfer-funds-to-linked-accounts/
- **Razorpay - Webhook validation and testing -** Raw-body signature validation, x-razorpay-event-id deduplication and out-of-order event warning. https://github.com/razorpay/razorpay-docs/blob/master/webhooks/validate-test.md
- **Razorpay - Subscription webhooks -** Subscription lifecycle events; match the current live API documentation and SDK. https://github.com/razorpay/razorpay-docs/blob/master/webhooks/subscriptions.md
- **PostgreSQL - Table Partitioning -** Partitioned-table unique/primary-key limitations. https://www.postgresql.org/docs/17/ddl-partitioning.html

19. Review limitation and final status

This correction pack resolves the major defects identified in the supplied PDF and gives replacement architecture and implementation controls. It does not replace a legal opinion, CA certificate, provider contract approval, production code review or external penetration test. It also does not reconstruct every paragraph of the original 105 pages. The correct next document-maintenance step is to merge these overrides into one clean, consolidated V2.1 master specification and remove all superseded V2.0 statements.

Final verdict

Gau-Sevak can move forward into architecture validation and sandbox implementation using this V2.1 pack. It is not approved for live money movement or tax-certificate issuance until the mandatory launch gates are completed and evidenced.